

Vendor AI Due Diligence Checklist

A practical checklist for screening, validating, and documenting third-party AI vendors before purchase, renewal, or expanded deployment.

Purpose

Use this checklist to confirm that an AI vendor has been properly profiled, that data handling and security controls are understood, that AI-specific risks have been addressed, and that the organization can defend its buying decision if leadership, customers, auditors, or common sense ask hard questions later.

Document Type	Operational Checklist Template	Version	1.0
Prepared For	{{COMPANY_NAME}}	Owner	{{VENDOR_RISK_OWNER}}
When to Use	Before purchase, pilot, renewal, or expansion	Related Artifact	3rd-Party AI Vendor Risk Review
Primary Users	Procurement, IT, security, privacy, legal, business sponsor	Status	Draft / Approved / In Use

How to use this checklist

- Use it as a process checklist, not as a substitute for judgment. A completed checklist with no thinking behind it is just paperwork cardio.
- Capture evidence as you go: links, questionnaires, contracts, security reports, architecture notes, and remediation commitments.
- Any vendor touching sensitive data, core business processes, or external-facing decisions should trigger deeper review before approval.
- Open gaps do not always mean “do not buy,” but they do mean “do not pretend.” Track them and assign conditions, owners, and due dates.

Checklist flow and decision guidance

The checklist is organized in the order a sensible team would usually review a vendor: establish context, understand data and security posture, review AI-specific governance, then land the decision cleanly.

1. Engagement context	2. Data, privacy, security	3. AI-specific controls	4. Decision and handoff
Business need, sponsor, deployment path, contract timing	Data types, access model, storage, security controls, legal terms	Model governance, training practices, human oversight, drift and change control	Residual risks, remediation conditions, approval path, next actions

Suggested dispositions

Outcome	When it fits	Typical next step
Approve	Low residual risk and controls are acceptable	Proceed with normal onboarding and register the vendor in the relevant inventory.
Approve with conditions	Minor or manageable gaps exist	Document conditions, due dates, owners, and any usage restrictions before rollout.
Escalate	Material risk, unclear evidence, or high-impact use case	Escalate to security, privacy, legal, executive sponsor, or AI governance forum.
Decline / pause	Unacceptable risk or unresolved control weakness	Do not buy, renew, or expand until the issue is materially addressed.

Minimum evidence to request

At a minimum, request the vendor questionnaire or equivalent written responses, security and privacy documentation, architecture or data flow summary, contract terms, subprocessors list, incident response commitments, and any AI-specific governance material the vendor can produce without fainting.

1. Engagement context and vendor profile

Confirm the organization knows what is being bought, who wants it, why it matters, and how the vendor fits into the environment before the due diligence gets lost in technical weeds.

Check	Required step or confirmation	What should be captured	Notes / evidence
☐	A business sponsor is identified and accountable	Business sponsor, team, and intended users are named.	{{SPONSOR}} / {{BUSINESS_UNIT}}
☐	The service or product being reviewed is clearly defined	Vendor name, product name, edition, modules, and deployment model are captured.	{{VENDOR}} / {{PRODUCT}} / {{DEPLOYMENT}}
☐	The intended use case is described in plain language	Business objective, user population, and whether the tool is internal or external facing are recorded.	{{USE_CASE_SUMMARY}}
☐	The procurement trigger is stated	New purchase, pilot, renewal, expansion, replacement, or emergency exception is identified.	{{PROCUREMENT_TRIGGER}}
☐	Key dates and commercial timing are understood	Desired go-live, contract timing, renewal date, and any urgent decision points are captured.	{{TIMELINE}}
☐	Integration scope is identified early	Planned integrations, SSO, API access, data connectors, or embedded model usage are listed.	{{INTEGRATIONS}}
☐	The vendor has a named point of contact for diligence	Sales, security, privacy, or technical contacts are available for follow-up.	{{VENDOR_CONTACTS}}

2. Data handling, privacy, and information lifecycle

This section checks whether the vendor touches the wrong data in the wrong way, which is usually how a “cool tool” becomes a compliance migraine.

Check	Required step or confirmation	What should be captured	Notes / evidence
☐	Data categories processed by the vendor are identified	Public, internal, confidential, regulated, customer, employee, source code, or other data types are listed.	{{DATA_TYPES}}
☐	Sensitive or regulated data exposure is explicitly assessed	PII, PHI, payment data, legal records, or other sensitive inputs are identified or ruled out.	{{SENSITIVE_DATA_ASSESSMENT}}
☐	The vendor's data flow is understood	Where data enters, is processed, stored, transferred, and deleted is documented.	{{DATA_FLOW_REFERENCE}}
☐	Training on customer data is confirmed or contractually restricted	Clarify whether prompts, files, telemetry, or outputs are used to train or improve the vendor's models.	{{TRAINING_POSITION}}
☐	Retention and deletion terms are reviewed	Retention windows, deletion rights, backup handling, and offboarding deletion process are captured.	{{RETENTION_AND_DELETION}}
☐	Subprocessors and hosting locations are disclosed	Material subprocessors, storage regions, and cross-border data transfer considerations are documented.	{{SUBPROCESSORS_AND_REGIONS}}
☐	Privacy commitments align with intended use	DPA, privacy notice, lawful processing basis, and data subject rights support are reviewed where applicable.	{{PRIVACY_EVIDENCE}}

3. Security, identity, access, and resilience

This section covers the controls that keep the vendor from becoming an open side door into your environment or a black box that collapses the first time something goes wrong.

Check	Required step or confirmation	What should be captured	Notes / evidence
☐	Identity and authentication model is reviewed	SSO support, MFA, local account controls, service accounts, and provisioning methods are documented.	{{IDENTITY_AND_AUTH_MODEL}}
☐	Role-based access and admin control model are understood	Privilege levels, admin roles, separation of duties, and access restriction capabilities are captured.	{{ACCESS_CONTROL_MODEL}}
☐	Security assurance evidence is requested and reviewed	SOC 2, ISO 27001, penetration tests, certifications, or security whitepapers are gathered.	{{SECURITY_ASSURANCE_EVIDENCE}}
☐	Encryption posture is confirmed	Encryption in transit and at rest, key management approach, and tenant segregation position are reviewed.	{{ENCRYPTION_POSITION}}
☐	Logging and audit visibility are available or planned	Admin logs, user activity logs, API logs, and export options are confirmed.	{{LOGGING_AND_AUDIT}}
☐	Incident response and breach commitments are documented	Notification terms, response obligations, and support paths for incidents are captured.	{{IR_COMMITMENTS}}
☐	Business continuity and service resilience are assessed	Availability commitments, backups, failover, disaster recovery, and support model are reviewed.	{{RESILIENCE_EVIDENCE}}

4. AI-specific governance and model risk controls

A normal SaaS review is not enough when the vendor's product uses AI. This section tests whether the vendor can explain how the magic trick works without acting offended that you asked.

Check	Required step or confirmation	What should be captured	Notes / evidence
☐	The AI capability used in the product is clearly described	Foundation model, embedded feature, agentic workflow, retrieval system, or custom model usage is identified.	{{AI_CAPABILITY_DESCRIPTION}}
☐	Human oversight expectations are defined	Confirm whether outputs require review before action and whether the tool supports reviewer checkpoints.	{{HUMAN_OVERSIGHT_MODEL}}
☐	High-impact decision use is identified or prohibited	Clarify whether outputs influence hiring, legal, financial, safety, customer, or regulated decisions.	{{DECISION_IMPACT_POSITION}}
☐	Testing, validation, or quality control practices are described	Vendor-provided evaluation methods, benchmark claims, or quality monitoring processes are captured.	{{MODEL_TESTING_INFO}}
☐	Model change management is understood	How the vendor handles model upgrades, feature changes, release notes, and customer notice is reviewed.	{{MODEL_CHANGE_PROCESS}}
☐	Bias, safety, and misuse safeguards are addressed	Content filtering, guardrails, abuse prevention, safety mitigations, and known limitations are documented.	{{SAFETY_AND_MISUSE_CONTROLS}}
☐	Explainability, transparency, or documentation is sufficient for the use case	Assess whether the vendor provides enough information for the organization to trust and govern the output.	{{TRANSPARENCY_POSITION}}

5. Legal, contractual, and commercial review

This section confirms the contract does not quietly undo the control posture you thought you had five pages ago.

Check	Required step or confirmation	What should be captured	Notes / evidence
☐	Contract terms align with the intended risk posture	Master terms, order form, and any AI-specific addenda are reviewed.	{{CONTRACT_SET}}
☐	Data ownership and usage rights are clear	The organization retains ownership of data, outputs, and restricted use rights are documented.	{{OWNERSHIP_AND_USAGE_RIGHTS}}
☐	Confidentiality obligations are adequate	Contract language protects prompts, uploaded files, outputs, and related business information.	{{CONFIDENTIALITY_TERMS}}
☐	Audit, assurance, or evidence rights are understood	Determine whether the organization can obtain updated reports, questionnaires, or notice of material changes.	{{AUDIT_RIGHTS}}
☐	Liability, indemnity, and limitations are reviewed	Commercial and legal stakeholders assess whether the balance is acceptable for the use case.	{{RISK_TRANSFER_POSITION}}
☐	Termination and exit terms are workable	Data export, deletion support, notice periods, and dependency risks are reviewed.	{{EXIT_TERMS}}
☐	Pricing and commercial model do not introduce hidden risk	Metering, usage caps, overage behavior, and expansion assumptions are understood.	{{PRICING_RISK_NOTES}}

6. Implementation readiness, conditions, and handoff

Before anything is approved, make sure the organization is actually ready to deploy the vendor without inventing controls later under stress.

Check	Required step or confirmation	What should be captured	Notes / evidence
☐	Implementation owner is named	Identify who will lead onboarding, configuration, and control implementation.	{{IMPLEMENTATION_OWNER}}
☐	Required technical controls are known before purchase	SSO, tenant configuration, logging, role restrictions, DLP, or network restrictions are identified.	{{REQUIRED_TECHNICAL_CONTROLS}}
☐	User guidance or acceptable use needs are identified	Determine whether employees need training, policy updates, or restricted use guidance.	{{USER_GUIDANCE_NEEDS}}
☐	Residual risks are documented plainly	Summarize open issues, caveats, and assumptions rather than burying them in side comments.	{{RESIDUAL_RISK_NOTES}}
☐	Conditions of use are defined if approval is conditional	List restricted data types, prohibited use cases, compensating controls, or time-boxed approvals.	{{CONDITIONS_OF_USE}}
☐	Registry and inventory updates are planned	Confirm where the vendor, tool, and related use cases will be recorded after approval.	{{TARGET_REGISTRY_OR_SYSTEM}}
☐	Renewal or re-review triggers are defined	Set what would trigger re-review: new integrations, new data types, major model change, incident, or expanded scope.	{{REREVIEW_TRIGGERS}}

7. Final review, conditions, and sign-off

Use this page to close the loop, document residual risk, and make the decision readable for the next person who inherits the file instead of guessing what happened.

Vendor	{{VENDOR_NAME}}	Review owner	{{REVIEW_OWNER}}
Business sponsor	{{BUSINESS_SPONSOR}}	Use case / service	{{SERVICE_NAME}}
Risk outcome	Approve / Approve w/ conditions / Escalate / Decline	Review date	{{DATE}}
Residual risk summary	{{SHORT_RISK_SUMMARY}}	Required restrictions	{{RESTRICTIONS_IF_ANY}}
Open actions	{{OPEN_ACTIONS_AND_DUE_DATES}}	Next review trigger	{{NEXT_REVIEW_TRIGGER}}
Decision record location	{{LINK_OR_REPOSITORY}}	Related artifacts	Procurement review / registry / contract file

Approval and conditions checklist

Check	Required step or confirmation	What should be captured	Notes / evidence
☐	Decision authority is clearly identified before procurement proceeds	Name the approver or forum that owns the final decision.	{{APPROVER_NAME_OR_FORUM}}
☐	Any conditions of approval are documented in writing	List conditions, restrictions, and due dates rather than trusting future memory.	{{CONDITIONS}}
☐	Contract, privacy, and security commitments are stored with the review record	Reference the contract file, security packet, or repository location.	{{FILE_LOCATION}}
☐	Vendor onboarding or rollout steps are aligned to the final decision	Confirm whether rollout may proceed, is limited, or is paused.	{{ROLLOUT_DECISION}}
☐	A follow-up review trigger is set	Examples: renewal, scope change, new data types, customer-facing expansion, material incident.	{{REVIEW_TRIGGER}}

Prepared by	{{NAME}}	Function	{{PROCUREMENT / SECURITY / PRIVACY}}
Reviewed by	{{NAME}}	Date	{{DATE}}
Approved by	{{NAME / FORUM}}	Signature / record	{{REFERENCE}}